

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

VULNERABILITY MANAGEMENT

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO094_00	00	30/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
IT Manager + RSGI	AD – Francesco Epifani	Riservato Alta Direzione + IT	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
30/04/2026	30/04/2026	30/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e ambito

La presente procedura definisce il processo di gestione delle vulnerabilità tecniche dei sistemi informativi di Toscana Diagnostica S.r.l., in attuazione di ISO/IEC 27001:2022 §A.8.8 (Management of technical vulnerabilities), A.8.29 (Security testing in development and acceptance), e di NIS2 (D.Lgs. 138/2024) art. 24 c. 2 area MTOM 5.

Ambito: tutti i sistemi informativi nel perimetro ISMS (LIS, RIS/PACS, AD, M365, infrastruttura di rete, endpoint, servizi cloud, integrazioni AI), oltre alla superficie applicativa esposta (portali, API, mobile).

2. Riferimenti

Riferimento	Ambito
ISO/IEC 27001:2022 §A.8.8, A.8.29	Vulnerability management; security testing
ISO/IEC 27002:2022 §8.8, §8.29	Linee guida implementative
D.Lgs. 138/2024 (NIS2) art. 24 c. 2	MTOM area 5 - sviluppo e manutenzione
TD-SGI-PRO018	ICT Change Management - integrato per patch deployment
TD-SGI-PRO070	Catena risposta a incidenti significativi
TD-SGI-PRO109	Information Security Policy operativa
TD-SGI-REG016 (SoA)	Riferimento ai controlli A.8.8, A.8.29
NIST SP 800-40 r4	Linee guida operative VM
CVSS v4.0 (FIRST)	Sistema di scoring vulnerabilità

3. Fonti di rilevazione delle vulnerabilità

Fonte	Cadenza	Owner
Threat Intelligence MSSP / SOC esternalizzato	Continuativa - alert ad-hoc	MSSP + IT Manager
Bollettini CSIRT Italia / CERT-AGID	Bisettimanali + alert	RSOI + IT Manager
NVD / NIST e CVE database	Continuativa	IT Manager
Vendor advisory (Microsoft Patch Tuesday, vendor LIS/RIS/PACS, vendor cloud)	Bisettimanale + on-disclosure	IT Manager
Vulnerability Assessment automatizzato (scanner interno)	Settimanale (scope esposto) + mensile (scope interno)	IT Manager
Penetration Test (esterno)	Annuale	IT Manager + Auditor di terza parte
Bug bounty / Responsible disclosure	Continuativa - canale dedicato sul sito	RSOI
Audit interno e di certificazione	Annuale	RSOI

4. Classificazione delle vulnerabilità (CVSS v4.0)

Classe	CVSS score	Tempo target di remediation	Escalation
Critica	9.0 - 10.0	≤ 24 ore (sistemi esposti) - ≤ 72 ore	AD + RSOI; possibile attivazione

		(sistemi interni)	PRO070 se exploited in-the-wild
Alta	7.0 - 8.9	≤ 7 giorni (esposti) - ≤ 30 giorni (interni)	RSGI
Media	4.0 - 6.9	≤ 30 giorni (esposti) - ≤ 90 giorni (interni)	IT Manager
Bassa	0.1 - 3.9	≤ 90 giorni o accettazione del rischio	IT Manager

Il tempo di remediation può essere prolungato solo con risk acceptance formale dell'AD + RSGI quando: (a) la patch è non disponibile dal vendor; (b) esiste mitigazione compensativa di pari efficacia (firewall, segmentazione, disabilitazione del servizio); (c) il sistema sarà dismesso entro un orizzonte definito.

5. Processo operativo

Fase	Attività	Owner	Output
1. Identify	Rilevazione vulnerabilità da fonti del §3	IT Manager + MSSP	Vulnerability ticket aperto
2. Assess	Valutazione applicabilità a TD; CVSS score; esposizione; sfruttabilità	IT Manager	Classificazione (Critica/Alta/Media/Bassa)
3. Prioritize	Ordinamento per priorità (CVSS + esposizione + criticità asset)	IT Manager	Backlog prioritizzato
4. Remediate	Patch / configurazione / mitigazione + Change Management (PRO018)	IT Manager + Vendor	Patch deployata e testata
5. Verify	Re-scan post-remediation per verifica chiusura	IT Manager	Ticket chiuso + evidenza
6. Report	Reporting mensile al RSGI; trimestrale al CdA per gravi	IT Manager + RSGI	Cruscotto VM
7. Lessons learned	Aggiornamento procedure / hardening baseline / inventario asset	RSGI	CAPA

6. Penetration Test

Cadenza minima: 1/anno per il perimetro esposto (portale paziente, API, mail security gateway). Programma triennale di copertura per il perimetro interno (rete clinica, AD, applicazioni amministrative).

Modalità: black-box per superficie esposta; grey-box per applicazioni interne critiche; coordinato con il vendor (per LIS/RIS/PACS) per non impattare sui dati clinici reali.

Output del PT: report con findings classificati per CVSS, raccomandazioni, esecutive summary. Findings High/Critical chiusi entro 90gg dal report.

7. KPI di processo

KPI	Target
% vulnerabilità Critiche chiuse entro SLA	≥ 95%
% vulnerabilità Alte chiuse entro SLA	≥ 90%
MTTR (mean time to remediate) Critiche	≤ 24h (esposti)

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

Numero VAPT completati nell'anno	≥ 1 PT esterno + 12 VA mensili
% asset coperti da scanning automatico	≥ 95%
% findings High/Critical PT chiusi entro 90gg	≥ 90%
Numero vulnerabilità critiche aperte > 30gg	0

8. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	30/04/2026	Prima emissione della procedura Vulnerability Management in attuazione di ISO 27001 §A.8.8 + §A.8.29 e di NIS2 area MTOM 5. Classificazione CVSS v4.0 con SLA differenziati per criticità ed esposizione. PT annuale + VA mensile. Chiude la NC P1 #24 del RPT003.	IT Manager + RSGI	AD